Cloud Shared Responsibility and Compliance Report

Name: Japheth Omondi

Date: June 16, 2026

1. Shared Responsibility Analysis

The shared responsibility model in a hybrid cloud environment delineates security obligations between the cloud service provider and the healthcare organization. The cloud provider is responsible for the security of the cloud, including physical infrastructure, hypervisors, and underlying network components. The healthcare organization is responsible for security in the cloud, including data classification, access management, encryption key stewardship, and compliance with regulatory frameworks such as HIPAA. The table below outlines specific responsibilities for each party based on the scenario provided.

Component	Cloud Provider Responsibility	Healthcare Organization Responsibility
Data Encryption	Provide encryption-at-rest capabilities for cloud storage services and TLS/SSL encryption for data in transit across the provider network.	Manage encryption keys for both on-premises and cloud environments; ensure key rotation policies; classify data according to sensitivity; verify that cloud backups are encrypted.
Access Control	Provide identity and access management (IAM) tools, role-based access control (RBAC) frameworks, and API access for user provisioning.	Define and enforce user roles; implement multi-factor authentication (MFA); conduct periodic access reviews; establish account lifecycle policies including automated deactivation.
Monitoring and Incident Response	Maintain cloud-native logging tools, infrastructure monitoring dashboards, and physical security event logging for data center facilities.	Integrate hybrid environment logs into a centralized logging system; configure automated alerting; develop and test incident response plans that account for hybrid cloud-specific risks.
Network Security	Secure physical network layers, maintain backbone routing infrastructure, and provide virtual network isolation primitives such as security groups and virtual private clouds (VPCs).	Configure network security group rules; implement network segmentation between on-premises and cloud workloads; restrict administrative access to specific IP ranges; upgrade on-premises firewalls to support modern

		features.
Backup and Recovery	Enable automated backup services for cloud-hosted resources; provide geographically redundant storage options; ensure backup infrastructure availability.	Test and document disaster recovery plans; encrypt backup data before storage; validate backup integrity; define recovery time objectives (RTO) and recovery point objectives (RPO).

2. Cloud Security Architecture Evaluation

This section evaluates the organization's current security posture against eight established cloud security best practices. Each practice is assessed as Implemented, Partially Implemented, or Missing, with a detailed explanation of the associated gap and its importance to the overall security and compliance posture of the hybrid environment.

Best Practice	Status	Notes (Gap/Importance)
Data encryption at rest and in transit	Partially	Cloud data is encrypted at rest and in transit; however, on-premises backups stored in the cloud are not encrypted. This creates a significant exposure: if the cloud backup storage is compromised, unencrypted PHI could be exfiltrated, constituting a reportable breach under HIPAA. Full encryption coverage across all data states and storage locations is essential for compliance.
Centralized key management	Missing	Encryption keys for on-premises and cloud environments are managed using different systems with no centralized control. This fragmentation increases the risk of key exposure, complicates rotation and revocation procedures, and prevents the organization from maintaining a unified audit trail of key usage. HIPAA requires that access to encryption keys be strictly controlled and auditable.
Multi-factor authentication (MFA)	Missing	No MFA is implemented for any user accounts accessing cloud or on-premises systems. This leaves the environment vulnerable to credential theft, phishing, and brute-force attacks. HIPAA Security Rule 164.312(d) mandates that covered entities implement procedures to verify that persons seeking access to electronic PHI are who

		they claim to be; MFA is the industry-standard control to satisfy this requirement.
Principle of least privilege	Partially	While some role separation exists, cloud-based user roles are manually managed with no defined lifecycle for account deactivation, and no periodic access reviews are conducted. This means dormant accounts may retain excessive privileges indefinitely, increasing the attack surface and violating the principle of least privilege. HIPAA requires regular review of access permissions to ensure they remain appropriate.
Automated monitoring, logging, and alerting	Partially	The cloud provider offers built-in monitoring tools, but the organization has not integrated logs from the hybrid environment into a centralized logging system. Without centralized correlation, the security team cannot detect cross-environment attack patterns, such as lateral movement from an on-premises compromise to cloud resources. HIPAA requires audit controls to record and examine access to electronic PHI.
Network segmentation	Partially	Cloud-hosted virtual machines are exposed to the internet for administrative access, albeit limited to a specific IP range. On-premises firewalls are outdated and cannot support modern security features such as deep packet inspection. This partial segmentation is insufficient: the exposed administrative surface creates a persistent target, and the inability to inspect traffic at the perimeter allows encrypted threats to pass undetected.
Regular vulnerability assessments	Missing	No vulnerability assessment program is described or evident in the current environment. Without regular scanning and penetration testing, unpatched systems and misconfigurations will persist indefinitely. HIPAA requires covered entities to implement procedures for guarding against, detecting, and reporting malicious software, which includes proactive vulnerability

		management.
Documented and tested disaster recovery plans	Partially	Backups are stored in the cloud, but disaster recovery plans are not documented or tested for hybrid cloud-specific risks. An untested plan is unreliable: recovery procedures may fail during an actual incident, leading to extended downtime and potential data loss. HIPAA requires contingency plans that include data backup and disaster recovery, with periodic testing to ensure effectiveness.

3. HIPAA Compliance Comparison

The Health Insurance Portability and Accountability Act (HIPAA) Security Rule establishes three categories of safeguards: Administrative, Physical, and Technical. This section maps the organization's current practices to each safeguard category, identifies compliance gaps, and specifies improvements needed to achieve full regulatory alignment.

HIPAA Requirement	Current Practice	Gap or Improvement Needed
Administrative Safeguards: Security Management Process (164.308(a)(1))	The organization has implemented some access controls but lacks formal security management processes. There are no periodic access reviews, no defined account lifecycle policies, and no documented risk analysis or risk management procedures.	Conduct a formal risk analysis; establish documented security policies and procedures; implement periodic access reviews; define and enforce account lifecycle policies including automated deactivation for terminated employees.
Administrative Safeguards: Assigned Security Responsibilities (164.308(a)(2))	Security responsibilities appear to be distributed informally across the IT team without clear assignment or accountability structures.	Designate a Security Officer with explicit responsibility for developing and implementing security policies; document roles and responsibilities; ensure accountability for security control maintenance.
Administrative Safeguards: Workforce Security (164.308(a)(3))	Cloud-based user roles are manually managed with no defined lifecycle for account deactivation, and no periodic access reviews are conducted for on-premises or cloud systems.	Implement automated provisioning and deprovisioning workflows; conduct quarterly access reviews; enforce the principle of least privilege through role-

		based access control with regular recertification.
Administrative Safeguards: Information Access Management (164.308(a)(4))	Access to PHI is not strictly governed by role-based policies. The absence of MFA and centralized logging means unauthorized access may go undetected.	Implement MFA for all systems accessing PHI; establish role-based access control with minimum necessary access; deploy centralized logging to monitor and audit all access to electronic PHI.
Administrative Safeguards: Security Awareness and Training (164.308(a)(5))	No security awareness training program is described or evident in the current environment.	Develop and deploy a mandatory security awareness training program for all workforce members; include phishing simulation, password hygiene, and incident reporting procedures; document training completion.
Administrative Safeguards: Security Incident Procedures (164.308(a)(6))	Incident response plans do not account for hybrid cloud-specific risks, and there is no centralized logging to support incident detection.	Update incident response plans to address hybrid cloud scenarios; integrate all logs into a centralized SIEM; establish automated alerting for anomalous access patterns; conduct tabletop exercises quarterly.
Administrative Safeguards: Contingency Plan (164.308(a)(7))	Backups are stored in the cloud but are not encrypted, and disaster recovery plans are not documented or tested.	Encrypt all backup data before cloud storage; document disaster recovery and data backup plans; define RTO and RPO; conduct annual disaster recovery testing and maintain test results.
Administrative Safeguards: Evaluation (164.308(a)(8))	No regular technical or non-technical evaluations of security policies and procedures are described.	Establish a recurring evaluation schedule including annual risk assessments, quarterly access reviews, and periodic penetration testing; document findings and remediation actions.
Physical Safeguards: Facility Access Controls	The cloud provider manages physical security for data center facilities. On-premises physical security is assumed	No gap identified for cloud facilities. Verify on-premises physical access controls

(164.310(a)(1))	to be managed by the organization.	through periodic audits; ensure visitor logs and badge access systems are maintained.
Physical Safeguards: Workstation Security (164.310(b))	Workstation security policies are not described in the scenario and may be informal or absent.	Document workstation security policies; implement screen locks, encryption for local storage of PHI, and physical security measures for workstations in shared or public areas.
Technical Safeguards: Access Control (164.312(a))	Cloud data is encrypted at rest and in transit, but encryption keys are fragmented across systems. MFA is not implemented. Unique user identification exists but is not reinforced by strong authentication.	Implement MFA for all users; centralize key management under a hardware security module (HSM) or cloud-native key management service (KMS); enforce automatic logoff after periods of inactivity.
Technical Safeguards: Audit Controls (164.312(b))	Cloud-native logging is available but not centralized. On-premises and cloud logs are not correlated, preventing effective audit trail analysis.	Deploy a centralized logging and SIEM solution that aggregates logs from both on-premises and cloud environments; configure automated alerting for unauthorized access attempts; retain logs for a minimum of six years per HIPAA requirements.
Technical Safeguards: Integrity (164.312(c)(1))	No mechanisms are described to protect electronic PHI from improper alteration or destruction.	Implement file integrity monitoring (FIM) for critical systems and databases; use digital signatures or checksums to verify data integrity; restrict write access to authorized personnel only.
Technical Safeguards: Person or Entity Authentication (164.312(d))	Authentication relies solely on single-factor username and password credentials, which is insufficient for protecting PHI.	Implement multi-factor authentication for all systems accessing electronic PHI; enforce strong password policies; deploy privileged access management (PAM) for administrative accounts.
Technical Safeguards:	Data in transit is encrypted using	Verify that all internal on-

Transmission Security (164.312(e))	TLS/SSL for cloud communications. On-premises transmission security is not explicitly described.	premises network traffic containing PHI is also encrypted using TLS or IPSec; ensure that encryption protocols are current and not vulnerable to known downgrade attacks.

4. Recommendations for Improvement

Based on the findings documented in Sections 2 and 3, the following recommendations are prioritized by urgency and mapped to specific HIPAA requirements and industry-standard frameworks. Each recommendation includes a clear rationale and expected impact on compliance and overall security posture.

Recommendation 1: Implement Multi-Factor Authentication (MFA) for All Accounts

Deploy MFA across all cloud and on-premises systems that process, store, or transmit PHI. This includes administrative accounts, service accounts with elevated privileges, and end-user accounts. Use time-based one-time passwords (TOTP) or hardware tokens rather than SMS-based MFA, which is vulnerable to SIM-swapping attacks. Enforce MFA through conditional access policies that block non-compliant sign-in attempts.

Rationale and Impact: MFA directly satisfies HIPAA Technical Safeguard 164.312(d) by ensuring that stolen credentials alone cannot grant access to PHI. It mitigates the risk of unauthorized access from phishing, credential stuffing, and brute-force attacks. Implementation should be completed within 30 days.

Recommendation 2: Centralize Encryption Key Management

Migrate all encryption key management to a unified platform, such as a cloud-native Key Management Service (KMS) or an on-premises Hardware Security Module (HSM) with cloud integration. Implement automated key rotation, strict access controls, and comprehensive audit logging for all key lifecycle events.

Rationale and Impact: Centralized key management addresses the fragmentation identified in Section 2 and satisfies HIPAA requirements for controlling and auditing access to encryption keys. It reduces the risk of key compromise, simplifies compliance audits, and enables rapid key revocation in the event of a suspected breach. Target completion: 60 days.

Recommendation 3: Encrypt All Backup Data Before Cloud Storage

Ensure that all backup data, including on-premises backups stored in the cloud, is encrypted using AES-256 encryption prior to transmission. Manage encryption keys

through the centralized KMS and verify that backup integrity checks are performed after each backup cycle.

Rationale and Impact: Unencrypted backups represent a critical compliance gap. Encrypting backups before storage ensures that even if cloud storage credentials are compromised, the underlying PHI remains protected. This aligns with HIPAA Technical Safeguard 164.312(a) and Administrative Safeguard 164.308(a)(7). Target completion: 30 days.

Recommendation 4: Deploy a Centralized Security Information and Event Management (SIEM) Solution

Integrate logs from all on-premises systems, cloud services, network devices, and identity providers into a centralized SIEM platform. Configure correlation rules to detect anomalous access patterns, failed authentication attempts, and potential data exfiltration. Establish automated alerting with defined escalation procedures.

Rationale and Impact: A centralized SIEM closes the monitoring gap identified in Section 2 and satisfies HIPAA Audit Control requirements under 164.312(b). It enables real-time threat detection, supports forensic investigations, and provides the audit trail necessary for regulatory compliance. Target completion: 90 days.

Recommendation 5: Establish a Formal Vulnerability Management Program

Implement quarterly vulnerability scanning using a commercial-grade scanner, annual penetration testing by a third-party firm, and a defined patch management cycle with service-level agreements (Critical: 72 hours, High: 7 days, Medium: 30 days). Document all findings, remediation actions, and exception approvals.

Rationale and Impact: Proactive vulnerability management satisfies HIPAA requirements for guarding against malicious software and supports the Security Management Process under 164.308(a)(1). It reduces the window of exposure for known vulnerabilities and demonstrates due diligence to auditors. Target completion: 60 days for program establishment; ongoing thereafter.

Recommendation 6: Upgrade On-Premises Firewalls and Implement Network Segmentation

Replace outdated on-premises firewalls with next-generation firewalls (NGFW) capable of deep packet inspection, application-layer filtering, and intrusion prevention. Implement network segmentation to isolate PHI-processing systems from general corporate networks and internet-facing services. Restrict administrative access to cloud virtual machines through a bastion host or VPN gateway.

Rationale and Impact: Modern firewalls and network segmentation reduce the attack surface, prevent lateral movement, and satisfy HIPAA requirements for transmission security and access control. Restricting internet-facing administrative access eliminates a high-risk exposure vector. Target completion: 90 days.

Recommendation 7: Document and Test Disaster Recovery Plans for Hybrid Cloud Scenarios

Develop comprehensive disaster recovery plans that define specific procedures for restoring on-premises and cloud systems, including failover sequences, data synchronization checks, and communication protocols. Conduct tabletop exercises quarterly and full-scale recovery tests annually. Define and document RTO and RPO targets.

Rationale and Impact: Documented and tested disaster recovery plans satisfy HIPAA Administrative Safeguard 164.308(a)(7) and ensure organizational resilience. Testing validates that recovery procedures function as intended and identifies gaps before an actual incident occurs. Target completion: 60 days for documentation; quarterly exercises thereafter.

Recommendation 8: Implement Automated Account Lifecycle Management and Periodic Access Reviews

Deploy an identity governance and administration (IGA) solution to automate user provisioning, role assignment, and deprovisioning. Enforce quarterly access reviews for all systems handling PHI, with manager attestation and automatic revocation of excessive or dormant privileges.

Rationale and Impact: Automated lifecycle management and access reviews enforce the principle of least privilege, reduce the risk of orphaned accounts, and satisfy HIPAA Workforce Security and Information Access Management requirements under 164.308(a)(3) and 164.308(a)(4). Target completion: 90 days.

Recommendation 9: Establish a Security Awareness and Training Program

Develop a mandatory, recurring security awareness training program covering phishing recognition, password security, incident reporting, and HIPAA privacy requirements. Conduct simulated phishing campaigns quarterly and track completion rates. Require annual refresher training for all workforce members.

Rationale and Impact: Workforce training satisfies HIPAA Administrative Safeguard 164.308(a)(5) and reduces the likelihood of human-error-based breaches. Documented training records provide evidence of compliance during audits. Target completion: 45 days for initial rollout; ongoing quarterly campaigns.

Recommendation 10: Implement File Integrity Monitoring (FIM) for Critical Systems

Deploy FIM software on all servers, databases, and endpoints that store or process PHI. Configure alerts for unauthorized changes to system files, configuration files, and database schemas. Integrate FIM alerts into the centralized SIEM for correlation with other security events.

Rationale and Impact: FIM satisfies HIPAA Technical Safeguard 164.312(c)(1) by detecting unauthorized alterations to electronic PHI. It provides early warning of compromise and supports forensic analysis by maintaining a record of all file changes. Target completion: 90 days.